

Adaptive Web Vulnerability Scan Report

Target: <https://owasp.org/www-project-webgoat/>

Scan ID: 812cda41-a517-4cd4-9468-bd7c486bbf38

Pages 18	Forms 5	Endpoints 99	Findings 3	API endpoints 6
GraphQL endpoints 2	Average anomaly 0	Passive score 90	High-risk endpoints 3	Schema fuzz probes 0
Open ports 5	Authenticated context No			

Scan Profile

Profile Bounty Standard	Detectors sqli, xss, csrf, auth_bypass	API fuzzing Enabled	GraphQL checks Enabled	Rate limit / sec 3.0
----------------------------	---	------------------------	---------------------------	-------------------------

Severity split: High 0, Medium 3, Low 0

Recon Intelligence

WAF Cloudflare	TLS TLSv1.3	Screenshot failed	Missing headers 0
-------------------	----------------	----------------------	----------------------

Technologies: vue cloudflare

Open ports: 80 http 443 https 8000 dev-http 8080 proxy-or-dev-http 8443 alt-https

Endpoint Risk Ranking

Risk	Method	Source	URL	Reasons
65	post	common-probe	https://owasp.org/rest/user/login	login keyword, rest keyword, user keyword
60	post	common-probe	https://owasp.org/api/graphql	graphql keyword, api keyword
55	get	common-probe	https://owasp.org/rest/products/search?q=apple	rest keyword, search keyword, parameterized
45	post	common-probe	https://owasp.org/graphql	graphql keyword
25	get	crawler	https://owasp.org/search	search keyword
25	get	crawler	https://owasp.org/donate/?reponame=www-project-webgoat&title=OWASP+WebGoat	parameterized
25	get	hidden-api	https://owasp.org/www-project-api-security-testing-framework/	api keyword
25	get	hidden-api	https://owasp.org/www-project-api-security/	api keyword

Risk	Method	Source	URL	Reasons
25	get	hidden-api	https://owasp.org/www-project-crapi/	api keyword
25	get	hidden-api	https://owasp.org/www-project-enterprise-security-api/	api keyword
25	get	hidden-api	https://owasp.org/www-project-rapid-developer-driven-threat-modeling/	api keyword
25	get	hidden-api	https://owasp.org/www-project-secure-api-gateway-blueprint/	api keyword
25	get	common-probe	https://owasp.org/api	api keyword
25	get	common-probe	https://owasp.org/rest	rest keyword
25	get	common-probe	https://owasp.org/api/Products	api keyword
25	get	common-probe	https://owasp.org/rest/products	rest keyword
10	get	crawler	https://owasp.org/www-project-webgoat/	standard surface
10	get	bundle-candidate	https://owasp.org/cdn-cgi//email-protection	standard surface
10	get	bundle-candidate	https://owasp.org/cdn-cgi/scripts/5c5dd728/cloudflare-static/email-decode.min.js	standard surface
10	get	bundle-candidate	https://owasp.org/www-policy/operational/general-disclaimer.html	standard surface
10	get	bundle-candidate	https://owasp.org/cdn-cgi/styles/cf.errors.css	standard surface
10	get	bundle-candidate	https://owasp.org/cdn-cgi/styles/cf.errors.ie.css	standard surface
10	get	crawler	https://owasp.org/contact/	standard surface
10	get	bundle-candidate	https://owasp.org/assets/images/web/about_header.png	standard surface
10	get	bundle-candidate	https://owasp.org/chapters	standard surface

Scan Timeline

Progress	Phase	Message	Timestamp
5%	startup	Target reachable and scan initialized	2026-05-16T05:18:33.719316+00:00
30%	crawl	Mapped 18 pages, 5 forms, and 99 endpoints	2026-05-16T05:19:00.070636+00:00
88%	validation	Validated 3 candidate findings	2026-05-16T05:20:09.558864+00:00
92%	recon	Passive recon, endpoint risk, TLS, and low-impact discovery completed	2026-05-16T05:20:15.580950+00:00

Detector Registry

sqli injection

query / form / api

Tests query parameters, forms, and API-like inputs for error-based, boolean-based,

xss client-side

query / form / api / dom

Checks reflected, DOM-rendered, and persistence-oriented XSS indicators

csrf workflow

form

Flags state-changing forms and endpoints that appear to lack anti-CSRF protections.

auth_bypass authorization

page / api

Looks for privileged or admin-style resources that are

and time-delay SQL injection signals.

across common input surfaces.

reachable without expected access controls.

API Surface

API endpoints
6

GraphQL endpoints
2

Parameterized endpoints
3

Methods
GET, POST

Discovery sources: bundle-candidate, common-probe, crawler, hidden-api, id-enumeration, script-analysis

Schema-Aware Fuzzing

Method	URL	Fields	Status	Reflected Fields	
No REST schema fuzz probes recorded.					

GraphQL URL	Fields	Status	Data Keys	Errors	
No GraphQL schema probes recorded.					

Detector Timings

Detector	Elapsed (ms)	Findings
sqli	55251.8	0
xss	13863.05	0
csrf	0.04	3
auth_bypass	373.0	0

Findings

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** https://owasp.org/rest/user/login
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST https://owasp.org/rest/user/login with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status - -> -, length - -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** https://owasp.org/graphql
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST https://owasp.org/graphql with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status - -> -, length - -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** https://owasp.org/api/graphql
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST https://owasp.org/api/graphql with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status - -> -, length - -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

Raw Findings Table

Detector	Severity	CVSS	Priority	Confidence	Signals	Method	Parameter	URL	Evidence	Po
csrf	medium	6.1	P2	medium (-)	-	post	-	https://owasp.org/rest/user/login	POST form does not expose an obvious CSRF token field	PC htt wit -
csrf	medium	6.1	P2	medium (-)	-	post	-	https://owasp.org/graphql	POST form does not expose an obvious CSRF token field	PC htt pa
csrf	medium	6.1	P2	medium (-)	-	post	-	https://owasp.org/api/graphql	POST form does not expose an obvious	PC htt wit -

[illegible]